

Contents

The Hub — Project Scope	1
1. Overview	1
2. User Types & Permissions	1
3. Location Category Taxonomy	3
4. Core Features	4
4.1 Onboarding & Profile Questionnaire	4
4.2 Search & Discovery	4
4.3 Location Profile Page	5
4.4 Reviews & Ratings	5
4.5 Favorites & Lists	5
4.6 Notifications	6
4.7 Admin Console	6
4.8 Agency Console	6
4.9 Recommendation Chatbot	6
5. Listing Lifecycle	7
6. Data Model Sketch	7
7. Monetization — Pay-Per-Boost	8
8. Recommendation Engine & ML Build Plan	9
9. Platform & Languages	9
10. Payments	10
11. Proposed Tech Stack	10
12. Security, Privacy & Compliance	11
12.1 Authentication & Account Security	11
12.2 Authorization & API Security	12
12.3 Data Protection	12
12.4 Payment Security	12
12.5 Abuse & Fraud Prevention	13
12.6 Infrastructure & Operational Security	13
12.7 Compliance & Legal	13
13. Content Moderation Policy	13
14. Analytics & Success Metrics	14
15. Accessibility & Localization QA	14
16. Suggested Phasing & Rough Timeline	14
17. Out of Scope for V1	15
18. Open Risks / Decisions to Track	15
19. Keys, Accounts & Third-Party Services Needed	15

The Hub — Project Scope

1. Overview

The Hub is a marketplace and discovery platform where users create a free account, complete a profile questionnaire, and receive personalized suggestions for activities and services near them — hiking, restaurants, events, gyms, supermarkets, stores, travel offices, and other location-based services, modeled after the breadth of Google Maps' place database but without map functionality.

Initial launch market: **Lebanon**. The architecture should not hardcode this assumption, so future geographic expansion is straightforward.

2. User Types & Permissions

Role	Description	Key Permissions
Super Admin (Michel)	Platform owner	Full control: manage Admins, platform configuration, financial oversight, override any decision, access to all data and logs, and sole authority to change platform-wide rules (e.g. the Lebanon-only geographic restriction in Section 9, fee structures)
Admin (internal team)	Operations staff	Approve/reject listings and claims, moderate reviews and content, directly edit any Location, Agency, or User record, edit the onboarding questionnaire (Section 4.1), manage end users, view analytics — no platform-config, financial access, or rule-changing authority unless explicitly granted by Super Admin
End User	Free account	Complete profile questionnaire, search/browse, save favorites & lists, receive personalized suggestions; leave reviews & ratings once phone/email verified (Section 4.4)
Agency	Paid — represents multiple locations	Manage multiple linked location profiles from one dashboard, purchase boosts for any of them at a discounted rate, view aggregated analytics across all managed locations
Individual Location	Paid — single business	Manage its own profile (photos, description, documents, hours, contact), purchase boosts at full list price, respond to reviews, view its own analytics

Permissions should be enforced through role-based access control (RBAC) at the API layer, not just hidden in the UI — every endpoint checks the caller's role before returning data or allowing a write.

Signup/signin method by role: End Users can sign up via email or social/OAuth login (Section 11). Agency and Individual Location accounts are **email signup/signin only** — no social

login — since these are business accounts tied to a verified business contact (email + the verified phone number from Section 5), and restricting them to email keeps identity/ownership verification straightforward.

3. Location Category Taxonomy

To support meaningful filtering and recommendations, locations need a structured taxonomy rather than a flat tag list. Below is a starting set of parent categories with representative subcategories — adjust naming/grouping as local market research dictates, but this gives the dozens of leaf categories the search and recommendation engine need to function well from day one.

Parent Category	Example Subcategories
Food & Drink	Restaurants, Cafés & Coffee Shops, Bars & Pubs, Bakeries & Patisseries, Fast Food, Fine Dining, Food Trucks, Dessert & Ice Cream Shops, Catering Services
Health & Wellness	Gyms & Fitness Centers, Yoga & Pilates Studios, Spas & Wellness Centers, Medical Clinics, Dentists, Pharmacies, Mental Health & Therapy, Nutritionists & Dietitians, Physiotherapy Centers
Beauty & Personal Care	Hair Salons & Barbershops, Nail Salons, Skincare & Aesthetics Clinics, Makeup Studios, Tattoo & Piercing Studios
Shopping & Retail	Supermarkets & Grocery Stores, Clothing & Fashion Boutiques, Electronics Stores, Bookstores, Furniture & Home Decor, Gift Shops, Convenience Stores, Specialty & Artisan Shops
Travel & Accommodation	Hotels & Resorts, Guesthouses & B&Bs, Travel Agencies, Car Rental Services, Tour Operators
Outdoor & Nature	Hiking Trails, Parks & Nature Reserves, Beaches, Campgrounds, Adventure Sports (rafting, ziplining, climbing)
Entertainment & Leisure	Cinemas, Theaters & Performing Arts, Museums & Galleries, Amusement & Theme Parks, Bowling Alleys & Arcades, Live Music Venues
Nightlife	Nightclubs, Lounges & Rooftop Bars, Karaoke Bars, Live DJ/Music Bars
Events & Venues	Wedding & Banquet Halls, Conference & Business Event Venues, Festival & Pop-up Spaces, Private Party Venues
Kids & Family	Playgrounds & Indoor Play Areas, Daycare & Nurseries, Kids' Entertainment Centers, Family-Friendly Activity Spots
Pets	Veterinary Clinics, Pet Grooming, Pet Stores & Supplies, Pet Boarding & Daycare

Parent Category	Example Subcategories
Professional & Home Services	Cleaning Services, Home Repair & Maintenance, Interior Design, Moving Services, Legal Services, Accounting & Financial Services, Real Estate Agencies
Automotive	Car Dealerships, Auto Repair & Maintenance, Car Wash, Auto Parts Stores
Education & Learning	Schools, Universities & Colleges, Tutoring Centers, Language Schools, Vocational & Skill Training Centers
Religious & Community	Places of Worship, Community Centers, NGOs & Charity Organizations
Finance & Essential Services	Banks & ATMs, Insurance Agencies, Currency Exchange, Notary & Government Service Centers

That is 16 parent categories and roughly 80 subcategories — comfortably “dozens,” with room to grow. Each location should be assignable to one primary category and optionally several secondary tags (e.g. a hotel with a spa can sit under Travel & Accommodation but tag into Beauty & Wellness too), since the recommendation engine performs better with richer tagging than with a single rigid category.

4. Core Features

4.1 Onboarding & Profile Questionnaire

A short, skippable-but-encouraged quiz immediately after signup. Sample question set:

1. Which of these interest you? (multi-select from the category taxonomy above)
2. What’s your typical budget range for going out? (e.g. \$, \$, \$\$\$\$)
3. Who do you usually go out with? (solo, partner, friends, family with kids, large groups)
4. How far are you willing to travel for something you love? (walking distance, same city, anywhere in country)
5. Any dietary preferences or restrictions? (vegetarian, vegan, halal, gluten-free, none)
6. Any accessibility needs we should account for in suggestions? (wheelchair access, etc.)
7. How often do you go out / try new places? (daily, weekly, occasionally)
8. Preferred language for the app? (Arabic, English, French)

Answers seed the cold-start recommendation logic before any behavioral data exists, and should remain editable from account settings — preferences drift over time.

4.2 Search & Discovery

- Keyword search across name, description, category, and tags.
- Filters: category/subcategory, distance radius, price range, rating threshold, “open now,” and accessibility flags.
- Sort by: relevance, distance, rating, newest.
- Featured/boosted listings surfaced distinctly (e.g. a “Featured” badge) so users understand why something is ranked high — transparency builds trust and is good practice regardless of local ad-disclosure norms.

- **Pay-to-win guardrail:** boosting is gated behind a minimum-rating eligibility floor (Section 7) — a location can’t simply outspend its way to the top regardless of quality, which keeps boosted placements from undermining the credibility of search results.

4.3 Location Profile Page

- Photo gallery, written description, uploaded documents where relevant (e.g. a restaurant menu PDF), link to the location’s Google Maps listing (this Maps link is also the location’s address of record — see Section 9), and contact details (phone, website, social).
- Tapping/clicking the phone number launches the device’s native phone dialer (tel: link on web, native dialer intent on mobile) to call directly — no in-app call screen.
- Category/subcategory + secondary tags, operating hours (with holiday-hours override support).
- Aggregate rating and review list, with the ability for the business to post a single public response per review.
- “Claimed” indicator so users can see whether the business itself manages the page or it’s still an Admin-seeded placeholder.

4.4 Reviews & Ratings

- One review per user per location, editable but not duplicable.
- Star rating (1-5) plus optional text and photos.
- **Verification gate to post:** an End User can browse, search, and favorite without verifying anything, but to publish a review their account must have a verified phone number (OTP code sent via SMS, same mechanism as Location verification in Section 5) and/or verified email. Unverified accounts can still read reviews, just not write them — this is the main lever against fake/drive-by reviews.
- **Reviewer score:** each User carries a reputation score derived from their review history — review volume, the like/dislike ratio their reviews receive from other users (below), and any moderation actions against them (flagged/removed reviews count against the score). The score is surfaced to other users (e.g. a “Trusted Reviewer” badge) and can be used to rank or weight reviews, and as an input signal for the recommendation engine’s trust weighting.
- **Likes/dislikes on reviews:** any other End User can mark a review as a like or dislike (one vote per user per review, changeable). Aggregated counts display on the review and roll up into the reviewing user’s reviewer score above.
- **Public name, private contact info:** the reviewer’s display name (and avatar, if set) appears publicly on every review they post. Their phone number and email are never shown — not on the review, not anywhere in the UI. Tapping/clicking the reviewer’s name opens a public reviewer profile showing their reviewer score/badge and a feed of all reviews they’ve posted (subject to the same moderation status as the main feed).
- Basic anti-abuse: rate-limiting per account on both reviews and likes/dislikes, profanity/spam filtering, and an Admin moderation queue for flagged reviews — vote manipulation (brigading a review with likes/dislikes) should be rate-limited the same way reviews themselves are.
- Future-friendly hook: a “verified visit” flag can be added later if a booking/check-in feature is introduced, but is not required for V1.

4.5 Favorites & Lists

- One-tap favorite on any location.
- Custom named lists (e.g. “Date night,” “Weekend hikes”) that can hold multiple locations.
- **List sharing:** a list can be switched from private to shared via a link (view-only for non-owners), or shared directly to another Hub user. Useful for planning with friends/family

(e.g. sending a “Weekend hikes” list to a group) and as a low-cost organic growth channel since shared links surface the Hub to non-users too.

- **The share link must open in the app, not a browser tab:** on a device with the Hub app installed, tapping the link opens the list directly inside the app (deep link), not a generic mobile-web page. If the recipient doesn’t have the app installed, the link falls back to an install prompt (app store) rather than a full browser-based list view — see Section 11 for the deep-linking mechanism.
- Sharing is opt-in per list — lists remain private by default, the owner decides if/when to generate a share link.

4.6 Notifications

- New listings matching a user’s profile interests.
- Responses to a user’s review.
- Boost purchase confirmations and expiry reminders (for Agencies/Locations).
- Approval/rejection status updates (for pending registrations and claims).
- Channel mix: push (mobile), email, and in-app notification center. SMS is optional and depends on confirming a Lebanon-reliable provider (see Section 14).

4.7 Admin Console

- Approve or reject new registrations and ownership claims, with a reason field that’s communicated back to the applicant.
- Moderate reviews and listing content (hide, edit-request, or remove with audit trail).
- Manage end users (suspend, reinstate) and locations (deactivate, archive).
- Platform analytics dashboard (see Section 11).
- Manually create/edit/import bulk listings for initial database seeding.

4.8 Agency Console

- Single login managing multiple linked Location profiles.
- Bulk actions where sensible (e.g. apply a boost campaign across several locations).
- Aggregated analytics across all managed locations, plus per-location drill-down.
- Visibility into the agency’s current discount rate/tier and how many more locations would unlock the next tier (see Section 7).

4.9 Recommendation Chatbot

- A conversational alternative to manual search: instead of typing filters, an End User can chat with an assistant that already knows their profile/questionnaire answers (Section 4.1) and asks clarifying follow-up questions (budget, mood, group size, area, etc.) to narrow down what they want.
- **Division of labor — LLM vs. recommendation engine:** the chatbot’s LLM is a conversational layer only. It understands the user’s natural-language input, asks follow-up questions, and writes the reply — but it never reasons over the location dataset itself or invents results. Every actual recommendation comes from the traditional recommendation engine in Section 8 (rule-based at launch, then content + collaborative filtering), which the LLM calls as a tool with structured parameters (category, area, budget, etc.) extracted from the conversation. This keeps recommendations consistent across chat and standard search, and keeps cost/latency bounded regardless of how large the location database grows — letting an LLM reason directly over thousands of locations on every request doesn’t scale, whereas the trained ranking model is cheap to run per-request.

- Conversation signals (what the user asks for, accepts, or rejects) feed back into the User’s interaction log (Section 8) as additional personalization input, the same way searches and favorites do.
- **Guardrails and abuse flagging:** the chatbot’s system prompt and tool-calling setup are designed to resist prompt injection — a user trying to get it to ignore its instructions, reveal the system prompt, or act outside the recommendation-assistant role. Beyond resisting manipulation, conversations are monitored for abuse patterns (repeated jailbreak attempts, spam, harassment) and flagged into the same Admin moderation queue used for reviews (Section 13); repeat offenders can be rate-limited or suspended the same way abusive reviewers are.
- **Can this be built:** yes — I can prototype this in-session as an LLM-backed conversational layer (provider-agnostic — GPT-4, Claude, or similar all work the same way here) with a system prompt grounded in the user’s profile, using tool-calling/function-calling to invoke the real recommendation engine rather than letting the model invent results. As with the rest of the recommendation engine (Section 8), I can build the prototype and service code now; production hosting, per-conversation cost/rate controls on LLM calls, and monitoring are your engineering team’s responsibility to deploy.
- Future-friendly hook: voice input is a natural V2 extension once the text-based chatbot is validated.

5. Listing Lifecycle

1. **Initial seeding** — Admin bulk-imports a baseline database of places (similar in breadth to what Google Maps offers, minus the map), so the catalog isn’t empty at launch.
2. **Claiming** — A business that finds its seeded listing can claim it, verifying ownership, to gain management rights as an Individual Location (or be grouped under an Agency).
3. **New registration** — Businesses not already in the database can self-register from scratch.
4. **Phone verification** — every Location must have a verified phone number before it can go live: an OTP code is sent via SMS to the listed number, and the number is marked verified once the code is confirmed. This applies to seeded, claimed, and newly registered listings alike — no listing goes live with an unverified number.
5. **Approval gate** — Every claim and new registration is reviewed and approved by an Admin before the account gains live management rights (phone verification is a prerequisite to approval, not a substitute for it).
6. **Featuring** — Once live, a location or its Agency can purchase a boost to be featured.

Ownership verification for claims should require some proof (e.g. a business document, a phone/email matching the listed contact, or a small confirmation charge) — without this, anyone could claim and edit someone else’s business. Phone verification (above) is the baseline check applied to every listing; additional proof may still be required for claims specifically.

6. Data Model Sketch

A rough entity outline to ground technical design — not a final schema:

- **User** — account, auth credentials, role, language preference, display_name (public), phone_number (private), phone_verified, email (private), email_verified, reviewer_score (public), is_deleted/deleted_at (set on account deletion — see Section 12.3 for what happens to the user’s reviews).
- **Profile** — questionnaire answers, derived preference vector, linked to a User.
- **Location** — name, category, subcategory, tags, description, hours, contact, google_maps_url (the location’s address of record — see Section 9), claimed status, owning Agency/Individual Location (nullable until claimed), phone_number, phone_verified (bool), phone_verified_at.
- **Media** — photos and documents, linked to a Location.

- **Review** — rating, text, photos, linked to a User and a Location, moderation status, likes_count, dislikes_count (denormalized from ReviewVote for fast reads).
- **ReviewVote** — a User’s like/dislike on a specific Review; one record per (User, Review) pair, feeds both the review’s like/dislike counts and the reviewing user’s reviewer_score.
- **Favorite / List / ListItem** — a User’s saved locations and custom groupings; List carries is_shared and a share_token for the public view-only link (Section 4.5).
- **Agency** — parent account that owns multiple Location records; carries a boost_discount_rate (or volume tier) applied automatically at checkout (see Section 7).
- **Boost / Campaign** — placement type, duration, price, payment status, linked to a Location, records the discount rate applied at time of purchase.
- **Transaction** — payment record, linked to a Boost purchase (pending payment-provider decision).
- **Notification** — type, recipient, read status.
- **AdminActionLog** — every approval, rejection, moderation action, with actor and timestamp, for accountability.

7. Monetization — Pay-Per-Boost

- Agencies and Individual Locations pay a one-off fee to feature a listing for a defined window.
- A boost increases visibility: higher placement in search results, category top spots, and/or homepage placement.
- **Individual Locations pay full list price** — they manage a single location and have no volume to leverage.
- **Agencies pay a discounted rate** on every boost they purchase, in exchange for managing multiple locations under one account — the discount is the incentive for agencies to consolidate their locations on the Hub rather than registering each one independently as an Individual Location.
- Illustrative pricing structure (placeholder numbers — finalize against local market research):

Placement	7 Days	14 Days	30 Days
Search/category boost — Individual Location (full price)	\$10	\$18	\$30
Search/category boost — Agency (discounted)	\$8	\$14	\$24
Category top spot — Individual Location (full price)	\$20	\$35	\$60
Category top spot — Agency (discounted)	\$16	\$28	\$48
Homepage feature — Individual Location (full price)	\$40	\$70	\$120
Homepage feature — Agency (discounted)	\$32	\$56	\$96

- The table above uses a flat 20% agency discount across all placements/durations. An alternative worth considering is a **volume-tiered** discount that scales with how many locations the agency manages (e.g. 10% off for 2–5 locations, 20% off for 6–15, 30% off for 16+) — this rewards larger agencies more aggressively and gives smaller agencies a reason to grow their portfolio on the platform. Either model is straightforward to implement since the discount is stored as a rate on the Agency record (Section 6) and applied automatically at checkout, rather than hardcoded into boost pricing.
- Recurring subscription tiers were considered but are **not** part of the initial model — worth revisiting once usage data shows demand for a bundled plan.
- **Currency: USD only.** All boost prices are charged and displayed in USD exclusively — no LBP pricing or dynamic exchange-rate conversion at checkout, which sidesteps Lebanon’s currency volatility entirely rather than trying to track it.
- **No refunds.** Boost purchases are final once paid — including if a Location is later suspended or removed mid-campaign, in which case the remaining campaign time is

simply forfeited rather than refunded. This must be stated clearly at checkout (not buried only in the ToS) so buyers aren't surprised.

- **Boost-eligibility floor:** a Location must meet a minimum rating threshold to purchase a boost at all (e.g. 3.0+ stars, with a minimum review count — such as at least 3 reviews — before a rating counts toward eligibility, to prevent gaming via too few reviews). This stops a low-quality listing from simply buying its way to the top of search and protects the trust of the ranking/recommendation system described in Sections 4.2 and 8.

8. Recommendation Engine & ML Build Plan

Can this be built, and by whom: yes — I can design and write a working first version of the recommendation system as code in this session: the data schema for preferences and interactions, a hybrid recommender (content-based filtering on profile/category data, blended with collaborative filtering once interaction data exists — e.g. using a library like LightFM or implicit), an evaluation script, and a FastAPI service that wraps the trained model behind an endpoint your backend can call. I can also generate synthetic interaction data to sanity-check the logic before real users exist.

What that doesn't cover: turning that prototype into a live, production-grade service is an infrastructure job, not a modeling job — hosting it with autoscaling, wiring it to your real production database, scheduling automatic retraining as new data comes in, and monitoring it for drift/SLA all require deployed cloud infrastructure that this sandboxed session doesn't have. The honest path is: I build and hand over a working model + service code and a clear technical spec, and your engineering team (or a hired contractor) deploys and operates it in production.

Practical rollout, given the ML cold-start problem: 1. **Launch:** rule-based matching (profile interests → category tags) — simple, deterministic, no data dependency. 2. **Early data collection:** instrument every search, view, favorite, and review as a logged interaction from day one, even while still on the rule-based system — this is the training data the ML model needs. 3. **First ML model:** once there's a few weeks/months of interaction data, train and deploy a hybrid content + collaborative filtering model; A/B test it against the rule-based baseline before fully switching over. 4. **Iterate:** retrain on a regular cadence (e.g. weekly) as more data accumulates.

Relationship to the chatbot (Section 4.9): this engine is the single source of truth for recommendations across the whole product. The chatbot's LLM is a conversational front-end on top of it, not an alternative recommendation method — the LLM extracts structured intent from chat and calls this engine, it does not rank or select locations on its own. This was a deliberate decision to keep recommendations consistent, debuggable, and cheap to run at scale (a trained model is near-free per request; an LLM call is not), rather than having the LLM reason over the full location dataset directly.

If you'd like, I can start that prototype now as a concrete code deliverable rather than just a plan — happy to do that as a follow-up.

9. Platform & Languages

- **Platform:** Web application and mobile app (iOS/Android), both planned from the outset.
- **Languages:** Arabic, English, French, with proper RTL handling for Arabic throughout web and mobile — this affects more than text direction: icons, navigation chevrons, form layouts, and number formatting all need RTL-aware design, not just a flipped stylesheet.
- **Geographic scope (V1):** the platform launches Lebanon-only. End Users must register with a Lebanese phone number, and Locations must have a Lebanese phone number — enforced via country-code validation on phone numbers (the same OTP mechanism

from Sections 4.4/5) and a country selector locked to Lebanon at signup and listing creation. Admins can manually add a Location or approve a User from another country as a one-off exception; only the Super Admin can change the underlying rule platform-wide (e.g. formally open up additional countries), per the rule-changing authority in Section 2.

- **Address representation — Google Maps link, not a formal address field:** Lebanon doesn't have a reliable formal postal/street-address system (addresses are often landmark-based), so a Location's address is captured as its Google Maps link/pin rather than a freeform or structured address string. This doubles as the existing "link to Google Maps" feature in Section 4.3 — it's the same field serving both purposes, not two separate pieces of data to collect and keep in sync.

10. Payments

Mainstream processors like Stripe are not available in Lebanon. **Current direction: 2Checkout (now Verifone)** as the payment gateway/merchant of record — as a MoR, it absorbs cross-border card processing, tax, and compliance overhead directly rather than requiring Lebanon-specific banking infrastructure. Lebanon appears in 2Checkout's published Middle East coverage, and Verifone's restricted-country list (OFAC-driven — Cameroon, Cuba, Iran, Libya, Sudan, Syria, Tunisia, North Korea, plus Russia) does not name it either.

- **Remaining step before relying on it:** being listed as a covered country is not the same as being an approved merchant — the actual onboarding application (business registration, banking/payout details, KYC) still needs to go through and get approved for a Lebanon-registered entity. Treat this as a confirmation step early in technical design, not a blocker to assume away.
- **Fallback options if onboarding hits a snag:** a local/MENA-friendly gateway (a Lebanese bank gateway, Whish, OMT, or similar), or manual/offline collection (bank transfer/cash) as an interim stopgap.

Recommendation: start the 2Checkout/Verifone merchant application early since it directly blocks the pay-per-boost revenue flow. Whatever is finalized, isolate it behind a payment-provider abstraction in the codebase so switching providers later doesn't require rewriting the boost-purchase flow.

11. Proposed Tech Stack

This is a starting recommendation to validate during technical design, not a final decision.

Layer	Suggestion	Why
Web frontend	Next.js (React) + Tailwind CSS	Strong i18n/RTL support, fast iteration, SEO-friendly for discovery pages
Mobile	React Native (Expo)	Shares logic/components with the React web app, single codebase for iOS + Android
Backend API	Node.js (NestJS)	Structured, scalable, good fit for a team building both web and mobile clients
Primary database	PostgreSQL + PostGIS	Relational integrity for users/locations/reviews, native geospatial queries for distance/location search

Layer	Suggestion	Why
Search	Elasticsearch or Algolia	Fast filtered, geo-aware, multi-language search
Recommendation service	Python (FastAPI) microservice	Industry-standard ML tooling (LightFM, implicit, scikit-learn) for hybrid content + collaborative filtering, can evolve toward embeddings/vector search later
File storage	AWS S3 / Cloudflare R2	Photos and uploaded documents (menus, etc.)
Auth	JWT; OAuth social login for End Users, email/password only for Agency & Individual Location accounts	Standard, mobile-friendly for consumers; email-only keeps business-account identity verification simple
Notifications	Firebase Cloud Messaging (push), SendGrid/Postmark (email)	Cross-platform push, reliable transactional email; SMS provider in Lebanon to be confirmed if needed
Maps	Google Maps Platform API (for linking out only, no in-app map)	Matches the “link to Google Maps” requirement without building map infrastructure
Deep linking	iOS Universal Links + Android App Links (e.g. via Branch.io or a self-hosted .well-known config)	Lets a shared list link open directly inside the native app instead of a browser tab; falls back to an app-store install prompt if the app isn’t installed (see Section 4.5)
Infra	Docker + AWS or GCP, CI/CD pipeline	Standard, scalable, supports multi-region growth later

12. Security, Privacy & Compliance

A concrete build checklist, organized by area, rather than a vague principle list — each item below is something an engineer should actually implement before launch.

12.1 Authentication & Account Security

- Password hashing with bcrypt or argon2 — never plaintext or reversible encryption.
- OTP-based phone verification for Locations and End Users posting reviews (Sections 4.4, 5): codes expire quickly (e.g. 5–10 minutes), are rate-limited per phone number/account to block brute-forcing, and are never logged or stored in plaintext.
- Agency/Individual Location accounts are email-only signup/signin (Section 2) — no weaker fallback like security questions; email verification required before the account can do anything paid.
- Short-lived access tokens with refresh tokens for sessions; users (and Admins, for a compromised account) can remotely revoke active sessions.

- Login rate-limiting/lockout after repeated failed attempts to block brute-force and credential-stuffing attacks.
- **TOTP authenticator app support for every account type:** any account — End User, Agency, Individual Location, Admin, or Super Admin — can enable an authenticator app (e.g. Google Authenticator, Authy, 1Password) as a second factor; this is not gated to a role-specific subset. For Super Admin and Admin accounts, MFA is **mandatory** (authenticator app preferred, SMS as a fallback) given these accounts have full data and financial access and are the platform’s highest-value targets. For End User, Agency, and Individual Location accounts, MFA is **optional but available to everyone** at V1 — surfaced as a security setting any user can turn on.

12.2 Authorization & API Security

- RBAC enforced server-side on every endpoint (Section 2) — the client-side UI hiding a button is not access control; the API must independently check the caller’s role on every request.
- **Public vs. private user fields:** an End User’s `display_name`, `reviews`, and `reviewer_score` are public by design. `phone_number` and `email` are private and must never be returned by any public-facing API response, rendered in any client view, or exposed on a reviewer’s public profile — enforced at the serializer/API layer, not just hidden in the UI.
- Input validation and sanitization on every endpoint (review text, profile fields, search queries) to prevent injection attacks (SQL injection, XSS) — especially important on free-text review content that gets rendered back to other users.
- File upload security: validate file type and size server-side (not just by file extension), scan uploaded documents/photos for malware, and serve them via signed/expiring URLs from storage rather than a publicly writable bucket.

12.3 Data Protection

- Encryption at rest for the database and uploaded business documents; TLS/HTTPS enforced everywhere in transit, no plaintext endpoints anywhere, including internal service-to-service calls.
- Secrets management: every API key from Section 19 (payment gateway, SMS/OTP provider, Maps, LLM, email) lives in a secrets manager (e.g. AWS Secrets Manager, GCP Secret Manager, or equivalent) — never committed to the repo or hardcoded in config files.
- Apply GDPR-style data-handling practices (clear consent for profile data, data export/delete on request) even though Lebanon’s regulatory requirements may be lighter — it’s good practice and removes friction if the platform expands to markets that do require it.
- **Defined data-retention policy:** explicit default retention periods per data category (account data, reviews, OTP codes/logs, audit logs, payment records) rather than indefinite retention by default — so data actually ages out on a schedule, and “delete on request” isn’t the only path to removal.
- **Account deletion does not delete reviews:** when a User deletes their account, their reviews stay up — preserving each Location’s review history and the integrity of its aggregate rating — but the review is re-attributed to a generic “Deleted User” label. The display name, avatar, and all PII (`phone_number`, `email`) are permanently scrubbed at that point; the review’s rating, text, photos, and like/dislike counts remain as they were.

12.4 Payment Security

- Tokenize through the payment gateway (2Checkout/Verifone, per Section 10) rather than storing card data directly — keeps PCI-DSS scope to the smallest applicable tier (typically

SAQ-A if checkout is fully hosted/tokenized).

- Never let card data touch your own servers or logs at any point in the flow.

12.5 Abuse & Fraud Prevention

- Rate-limit OTP requests, review submissions, and review likes/dislikes per account (Section 4.4) — this is a security control against brute-forcing and bot abuse, not just a product nicety.
- Run the fake-review and conflict-of-interest detection from Section 13 (Content Moderation Policy) as a standing defense, not a one-time launch feature.

12.6 Infrastructure & Operational Security

- Automated dependency/vulnerability scanning in CI (e.g. Dependabot, Snyk, or equivalent) so known-vulnerable packages get flagged before they ship.
- Audit log for every Admin moderation/approval action (see AdminActionLog in Section 6) — necessary for dispute resolution (“why was my listing rejected?”) and for spotting internal misuse.
- Regular backups and a documented, **tested** restore process before launch, not after an incident — a backup nobody has restored from is unverified.
- A basic incident-response plan written before launch: who gets notified on a suspected breach, what gets checked first, and what (if anything) needs to be disclosed to affected users — having this decided in advance prevents panic-driven mistakes during an actual incident.
- **Network-layer protection:** a Web Application Firewall (WAF) and DDoS mitigation in front of the API (e.g. Cloudflare, AWS Shield/WAF, or equivalent) — the app-level rate-limiting in 12.5 protects against abuse of specific features, but not a raw volumetric or L7 attack on the infrastructure itself.
- **Third-party security audit / penetration test scheduled before public launch:** internal review and this checklist catch known categories of issues, but an independent pentest is the standard way to catch what the team didn’t think to check — budget time and cost for this as a pre-launch gate, not an afterthought.

12.7 Compliance & Legal

- A Privacy Policy and Terms of Service must be drafted and reviewed by an actual lawyer before launch — covering data collected (Section 6), how it’s used, the GDPR-style rights above, and the payment/refund terms for boosts. I can draft a first pass, but it needs legal sign-off before being legally relied upon.

13. Content Moderation Policy

- **Reviews — ethics enforcement:** this is a priority, not a nice-to-have, since fake or manipulated reviews undermine the entire recommendation/trust model. Concretely:
 - Verification gate (Section 4.4) is the first line of defense — every review is tied to a phone/email-verified account, not an anonymous one.
 - Fake-review detection heuristics: flag accounts posting many 5-star (or many 1-star) reviews in a short window, reviews posted immediately after account creation, multiple reviews from the same device/IP across different accounts, and unusually similar review text across reviews (template/copy-paste abuse).
 - Conflict-of-interest rule: an Individual Location or Agency account (and anyone managing that listing) is blocked from reviewing their own listing or, ideally, direct competitors in the same category/area — enforced at minimum by policy and account-type checks, with manual Admin follow-up on suspected sock-puppet accounts.

- Disclosure requirement: if the Hub ever runs an incentivized-review program (e.g. “leave a review, get entered in a raffle”), incentivized reviews must be clearly labeled as such — never disguised as organic.
- Profanity/spam filtering, per-account rate limits on reviews and on like/dislike votes, and an Admin moderation queue for flagged content, with one public business response per review.
- Repeated ethics violations should feed into the reviewer score (Section 4.4) and can lead to account suspension (Section 4.7), not just removal of the individual review.
- Listings: Admin approval gate at creation/claim (Section 5); post-launch spot-checks for seeded listings that haven’t been claimed in a long time.
- **Chatbot abuse:** conversations with the recommendation chatbot (Section 4.9) are subject to the same moderation pipeline as reviews — flagged for prompt-injection attempts, harassment, or spam, feeding into the same Admin queue and account-suspension consequences as review-ethics violations.
- Appeals: a rejected claim, registration, or removed review should get a stated reason and a path to resubmit/appeal — silent rejection erodes trust with both businesses and end users.

14. Analytics & Success Metrics

Track from day one so Phase 2 decisions (ML rollout, subscription pricing, expansion) are data-driven rather than guesswork:

- Signup → questionnaire completion rate.
- Search-to-view and view-to-favorite conversion.
- Recommendation click-through rate (rule-based baseline vs. later ML model).
- Review submission rate per active user.
- Boost purchase conversion and repeat-purchase rate (segmented by Individual Location vs. Agency).
- Listing claim rate (seeded listings claimed vs. still unclaimed).
- DAU/MAU and 30-day retention.

15. Accessibility & Localization QA

- Basic WCAG-aligned practices: sufficient color contrast, alt text on images, screen-reader-friendly navigation on mobile.
- RTL testing as a first-class QA pass for Arabic, not an afterthought — test forms, tables, and navigation specifically in RTL mode, not just static text blocks.
- Font/number formatting QA across Arabic, English, and French, since locale-specific formatting (dates, currency) is easy to get wrong.

16. Suggested Phasing & Rough Timeline

Timeframes are rough planning estimates, not commitments — they depend heavily on team size.

Phase 1 — MVP (roughly 3-4 months with a small focused team) - Web app, Admin-seeded database, self-service registration with Admin approval, claiming flow. - Search, browse, favorites/lists, reviews & ratings. - Rule-based suggestions while real usage data accumulates; interaction logging running from day one. - Pay-per-boost with manual/offline payment collection if the gateway isn’t ready, including the Agency discount logic. - Arabic/English/French support.

Phase 2 (roughly 2-3 months after MVP) - Mobile app (iOS/Android). - First trained ML recommendation model, A/B tested against the rule-based baseline. - Automated payment

gateway integration. - Agency multi-location dashboard and analytics, volume-tiered discount logic if adopted.

Phase 3 (ongoing) - Geographic expansion beyond Lebanon. - Reassess subscription-tier monetization alongside pay-per-boost. - Re-evaluate booking/reservations and in-app messaging (explicitly out of scope for V1 — see Section 17).

17. Out of Scope for V1

- In-app booking/reservation system.
- In-app messaging between users and locations.
- Recurring subscription monetization (pay-per-boost only at launch).

These were considered during scoping and intentionally deferred rather than overlooked — worth revisiting once the core platform has traction.

18. Open Risks / Decisions to Track

- **Payments:** 2Checkout (Verifone) is the intended gateway (Section 10); Lebanon is in their listed coverage, but the merchant application/approval still needs to go through — highest-priority open item, directly blocks revenue.
- **Initial data seeding:** sourcing a Google-Maps-breadth dataset for Lebanon (gyms, restaurants, shops, etc.) without using Google's map itself needs a concrete data acquisition plan (manual entry, partner data, scraping within ToS limits, or a data licensing deal).
- **ML cold start:** the recommendation engine needs real usage data to outperform simple rule-based matching — budget time for the rule-based fallback and interaction logging rather than expecting ML quality at day one (see Section 8 for the realistic build plan).
- **Claim verification:** need a concrete method to verify a claimant actually owns the business before granting edit rights.
- **Agency discount structure:** decide flat-rate vs. volume-tiered discount (Section 7) before finalizing the Boost pricing/checkout logic.
- **SMS/notifications in Lebanon:** confirm which providers reliably deliver SMS/push there before committing to a vendor. This is now a launch-blocking dependency, not just a nicety — phone verification (Section 5) requires reliable OTP delivery for every listing to go live.
- **Local legal compliance (deferred):** Section 12.3's GDPR-style practices are a good-practice baseline, not a substitute for checking Lebanon's own data-protection/e-transactions law (Law 81/2018) with a local lawyer. Explicitly deferred for now per a scoping decision — revisit before launch, not skip entirely.

19. Keys, Accounts & Third-Party Services Needed

A consolidated list of every external account, API key, or developer credential the build depends on, pulled from the features described above. Prices below are approximate as of June 2026 and should be re-checked at purchase time since vendor pricing changes.

Service / Account	Used for	Free or paid	Approx. cost
Apple Developer Program	Publish the iOS app on the App Store (Section 9)	Paid, recurring annual	\$99/year
Google Play Console	Publish the Android app on Google Play (Section 9)	Paid, one-time	\$25 one-time, no renewal

Service / Account	Used for	Free or paid	Approx. cost
Domain name	App/marketing website address	Paid, recurring annual	~\$10-20/year depending on registrar and TLD
SSL certificate	HTTPS for web app	Free	\$0 — Let's Encrypt (or included free with most hosting providers)
2Checkout / Verifone merchant account	Payment processing for boost purchases (Section 10)	Paid, usage-based	No flat fee; a per-transaction processing fee (% + fixed amount) confirmed at merchant onboarding
SMS OTP provider (e.g. Twilio Verify or similar)	Phone verification for Locations and End Users (Sections 4.4, 5)	Paid, usage-based	~\$0.05 per successful verification plus SMS carrier cost (varies by country — confirm Lebanon-specific SMS rates, which can run higher than US rates)
Google/Apple/Facebook OAuth credentials	Social signup/login for End Users only (Section 2)	Free	\$0 to register as a developer and use; no per-login charge
Google Maps Platform API key	Linking to/embedding Google Maps listings (Section 4.3), geocoding	Paid, usage-based with a free monthly allotment	Roughly \$2-\$40 per 1,000 requests depending on the specific API used; an optional \$100/month Starter plan (50,000 calls) exists if usage is predictable
Firebase Cloud Messaging	Push notifications (Section 4.6)	Free	\$0 — unlimited push notifications
Transactional email service (e.g. SendGrid or Mailgun)	Verification emails, notifications	Paid (no permanent free tier as of 2026)	SendGrid Essentials from ~\$19.95/month (100k emails); Mailgun Foundation ~\$35/month (50k emails)

Service / Account	Used for	Free or paid	Approx. cost
LLM API key (e.g. Anthropic Claude or OpenAI)	Recommendation chatbot's conversational layer (Section 4.9)	Paid, usage-based	Billed per token — e.g. Claude Sonnet ~\$3/\$15 per million input/output tokens, GPT-4o ~\$2.50/\$10; total cost scales with chatbot usage volume, not a fixed monthly fee
Cloud hosting (AWS, GCP, or Azure)	Backend, database, recommendation-engine hosting (Section 11)	Paid, usage-based	No fixed price — typically a few hundred dollars/month at MVP scale, rising with traffic and storage
Object storage (e.g. AWS S3 or equivalent)	Photos, documents, review images (Section 6)	Paid, usage-based	Fractions of a cent per GB stored/transferred — negligible at MVP scale
Error monitoring (e.g. Sentry)	Catching production bugs/crashes	Free tier, paid above a threshold	Free tier covers low-volume MVP usage; paid tiers kick in as error/event volume grows
Source control (e.g. GitHub)	Codebase hosting, CI/CD	Free for small private teams; paid for larger orgs	Free at this team's likely size; a paid Team/Enterprise plan only matters if the engineering team grows substantially

Notes: - The two non-negotiable fixed costs before launch are the Apple Developer Program (\$99/year) and Google Play Console (\$25 one-time) — both are required just to distribute the mobile apps, regardless of feature set. - Everything else above is usage-based and scales with how many users, listings, and chatbot conversations the platform actually has — there's no way to give a single fixed “monthly cost” for the whole stack until real usage patterns exist; budget for a modest, predictable MVP-scale bill (rough low hundreds of dollars/month across hosting, SMS, and email) and expect it to grow with the user base. - Re-confirm the SMS OTP and payment-gateway transaction rates specifically for Lebanon before committing — quoted rates above are global/US baseline figures and may differ.